Natalyx MVP Fixes

Work Package 01: CI and PostgreSQL evidence gate

L. Rhodes (plan owner) - A. Zhao (technical feedback reconciled)

2026-07-12

Contents

1 Work Package 01: CI and PostgreSQL evidence gate **2**

1.1 Purpose and outcome . . . 2
1.2 Verified current-state evidence . . . 3
1.3 Architecture and contracts . . . 3
1.4 Explicit PR sequence . . . 4
1.5 Cross-repository coordination . . . 7
1.6 Test and acceptance matrix . . . 7
1.7 Risks and decisions . . . 8
1.8 Existing-work salvage . . . 9
1.9 Ownership recommendation . . . 11
1.10 Definition of done . . . 11

1 Work Package 01: CI and PostgreSQL evidence gate

Review draft only. Ownership and sequencing remain recommendations until Luke and Alan approve the plan together.

Plan	Value
Work package	WP01
Plan file	`WP01 - CI and PostgreSQL evidence gate.md`
Proposed PRs	P01-01
Inspection snapshot	2026-07-12 19:30 America/New_York

1.1 Purpose and outcome

Problem. Main builds containers and runs a deploy-contract smoke, but does not run the Python suite or prove current schema behavior against PostgreSQL.

Why this package exists. It creates a reviewable boundary so the programme can progress without mixing product, data, security, infrastructure and rollout concerns in one oversized change.

Completed outcome. A first, deliberately CI-only PR that runs the current tests, exercises the existing schema on PostgreSQL, and publishes diagnosable evidence under stable required-check names without introducing the future migration framework.

Explicit non-goals.

- No migration runner

- No product behavior changes
- No schema redesign
- No deployment

1.2 Verified current-state evidence

Classification is explicit: **verified** is observed code/PR/live behavior; **verified limitation** records an evidence gap; **design authority** is an approved planning source; **design decision** is proposed future behavior. None is silently treated as another.

ID	Class	Repository / ref	File, construct or location	Finding
E-005	verified	app / origin/main@fdf2bb4	.github/workflows/build.yml:1-42; aws-app-deploy.yml:1-38	Main builds images and runs a local deploy-contract smoke but has no Python test workflow or PostgreSQL evidence job.
E-006	verified	app / PR #122@e853821	PR comment Review round 2 addressed and changed workflow/tests	Updated PR #122 reports 499 tests plus return_to, TTL, CAS, self-invite, lens and Learn fail-closed fixes; green checks were observed. These are salvage candidates, not blanket merge approval.
E-009	verified	app / origin/main@fdf2bb4	app/storage/connection.py:14-57,93-123	The app supports pooled PostgreSQL and SQLite with a SQL compatibility adapter; PostgreSQL is the cloud backend but the current suite is predominantly local.
E-032	verified limitation	GitHub / 2026-07-12	private-repository branch-protection/ruleset API	The API returned a plan-level 403 requiring GitHub Pro or public visibility, so a stable workflow can be planned but bypass-resistant required-check enforcement cannot be claimed until D-CI-01 is resolved and read back.

1.3 Architecture and contracts

- PostgreSQL is production authority; SQLite remains a local compatibility target, not production evidence.
- Separate current-schema evidence from tests that require the future migration mechanism.

Contract area	Package rule
Ownership boundary	`app`; repository-specific PRs remain separate.
Entities/state	No new runtime entity; evidence/coordination only.

Contract area	Package rule
Authorization	Authenticated subject/service plus entity membership, role, purpose, consent and expected revision; query parameters, links and UI state are never authority.
API/service	No broad public contract; use the focused commands/events in each PR.
Storage	None; exercise the schema that main owns today.
Audit	Use the common transition envelope and append-only source/event identifiers; redact tokens, raw documents, prompts and sensitive payloads.
Failure	Fail closed for authorization, provenance, money, document and PHI boundaries; expose a bounded actionable error and preserve retry/repair evidence.
Observability	Correlation, policy/schema/config version, transition and dependency result metrics without PHI/PII payload logging.
Compatibility	Additive/dual-compatible changes, explicit version pins, old/new revision window and named forward repair.
Privacy/PHI	Synthetic only through A2; approved PII only at B1; PHI remains blocked until formal B2.

1.4 Explicit PR sequence

Order	ID	Title	Repository	Dependencies	Gate	Local preparation	Merge readiness
1	P01-01	Establish current-test and PostgreSQL CI evidence	app	P00-01	A0	Not ready; named PR, decision or programme-acceptance prerequisites remain	Blocked pending PR dependencies P00-01; technical decisions/controls D-CI-01; Luke review/final founder approval

1.4.1 P01-01 - Establish current-test and PostgreSQL CI evidence

Field	Plan
Repository / base	`app` (`main`)
Gate / size	A0 / Medium
Local preparation status	Not ready; named PR, decision or programme-acceptance prerequisites remain

Field	Plan
Merge readiness	Blocked pending PR dependencies P00-01; technical decisions/controls D-CI-01; Luke review/final founder approval
Technical-decision owner	D-CI-01: Alan - immediate control configuration/evidence
Dependencies	P00-01
Blocking decisions/checkpoints	D-CI-01
Source / salvage	PR #122 unittest workflow and backend-neutral fixes after reconciliation

1.4.1.1 Objective Run the current suite on pull requests/main and prove the existing schema boots and behaves on an ephemeral PostgreSQL service before any migration redesign.

1.4.1.2 Scope

- Stable, unfiltered unittest and PostgreSQL check names
- Pinned action SHAs and supported Python runtime
- Locked/constraint-backed dependencies, timeouts and cancellation
- Ephemeral PostgreSQL current-schema evidence
- Sanitized failure artifacts

1.4.1.3 Explicit non-goals

- No migration-version table
- No new-schema tests
- No application behavior

1.4.1.4 Expected files or modules

- `.github/workflows/python-tests.yml`
- `tests/python/test_postgres_current_schema.py`
- `scripts/ci_postgres_evidence.py`

1.4.1.5 Change map

Area	Planned change
Schema/model	None; exercise the schema that main owns today.
API/routes	No public API/route contract change.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	Add stable unittest and PostgreSQL evidence jobs; repository-side required-check enforcement remains D-CI-01 until independently read back.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

Area	Planned change

1.4.1.6 Tests and validation

Objective tests:

- Current Python suite
- workflow trigger/path-bypass contract
- init_db twice on PostgreSQL
- representative create/read/authorization path
- intentional failure log-redaction check

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A0** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.1.7 Diagnostics and observability

Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.1.8 Rollout

Ship expand-only and dark by default; run the one-off migrator, verify readiness/old-revision compatibility, then enable writers/readers in a later compatible step.

1.4.1.9 Rollback or forward repair

Prefer application rollback within the expand/contract window and a new forward-repair migration. An irreversible schema reversal requires its own approval and backup evidence.

1.4.1.10 Dependencies and parallel work

Hard dependencies: P00-01. Parallel opportunities: None inside this package beyond review/test preparation.

1.4.1.11 Objective acceptance criteria

- ☐ Run the current suite on pull requests/main and prove the existing schema boots and behaves on an ephemeral PostgreSQL service before any migration redesign.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.1.12 Ownership and review

Role	Recommendation
Work-package DRI	Alan
Primary implementer	Alan (proposed; pending Alan review)
Technical-decision owner	D-CI-01: Alan - immediate control configuration/evidence
Reviewer	Luke
Final approver	Luke
PR-level ownership exception	None
Required expertise	Python/FastAPI, PostgreSQL, security-aware product engineering
Higher-capability review	Risk-proportionate; not mandatory by programme default

1.5 Cross-repository coordination

Repository	Authority after merge
`app`	routing, validation, authorization, participant/case/workflow truth, PHI policy and commercial domain

Merge order inside this package: `P01-01`.

Handoff rule: producer contract/version must merge and be pinned before its consumer enables the feature. During a partial merge, consumers fail closed or retain the last approved version; they do not fabricate data or silently broaden access.

Compatibility window: keep prior readers/writers and rollback image usable through the named gate; contract/migration PRs document the exact removal point.

1.6 Test and acceptance matrix

Test dimension	Method	Objective result
Happy path	Current unit suite; Fresh PostgreSQL database; Current init_db idempotency; Failure artifact and log clarity	Expected state/event/UI and named evidence are produced once.
Authorization failure	Wrong/no subject, role, membership, purpose or consent	403/404 as appropriate; no write or data leak; audit safe failure.
Role differences	Separate IP, GC, operator, provider/service identities	Only the approved lens/projection/actions appear.
Retries/duplicates	Repeat same canonical request/event	Original result returned; no duplicate membership/case/invoice/document/event.
Concurrency	Two writers/claimants/migrators/workers	One valid transition; loser receives deterministic stale/conflict response.

Test dimension	Method	Objective result
Stale state	Old revision/config/terms/token/artifact	Fail closed or approved compatibility behavior; never silent coercion.
Malformed input	Boundary, encoding, size, enum, redirect and identifier corpus	Validation before side effects; safe error.
Unavailable dependency	Database, intelligence, processor, S3/scanner or auth unavailable	Explicit degraded/blocked behavior; no hallucinated success.
Partial failure	Crash between external effect, DB transaction and outbox	Retry/forward repair converges from durable evidence.
Logout/login/resume	Session expires/restarts mid-flow	Return to authorized current state; no query/link authority.
Mobile/accessibility	320/375/768 widths, keyboard, focus, reduced motion	Core task completes with truthful state and no clipped controls.
Synthetic cloud	Known dev revision and synthetic identities/data	Gate artifact records SHA, dependency status, audit and cleanup.
Audit/observability	Inspect events/metrics/logs	Versions, actor/authority, correlation and reason present; no sensitive payload.

1.7 Risks and decisions

Founder outcomes, Alan's remaining technical ownership and external activation dependencies are recorded separately so a final policy is never mistaken for an active control.

ID	Status	Classification	Remaining owner	Affected / latest	Programme effect
D-CI-01	Founder final; operationally pending	Luke decides commercial outcome; Alan configures immediately	Alan - immediate	P01-01; Founder decision resolved 2026-07-13; control required before P01-01 merge or any later app implementation PR	P01-01 merge, Gate A0 and dependent implementation PRs remain blocked until the live control is active and verified.

1.7.1 D-CI-01 - Required-check enforcement for the private app repository

Field	Recorded decision or requirement
Decision state	Final founder decision; control pending
Founder outcome	Option A - GitHub Team approved as the private-repository enforcement control.

Field	Recorded decision or requirement
Founder constraints	Approximately $12 USD/month before tax for three billable users; Commercial decision is final; Expenditure is authorized but not yet incurred; No claim of bypass-resistant enforcement before live configuration and readback
What remains for Alan	Activate GitHub Team when enforcement is required; Configure required unittest and PostgreSQL checks; Restrict routine bypass; Supply ruleset readback and negative-bypass evidence
Evidence required	GitHub Team activation/readback; Mandatory unittest and PostgreSQL checks; Restricted routine bypass; Negative-bypass evidence
Approval rule	Luke accepts the enforcement evidence; the approved purchase itself needs no further founder decision.
External dependencies	GitHub Team activation; expenditure authorized but not yet incurred
Affected PRs / latest point	P01-01; Founder decision resolved 2026-07-13; control required before P01-01 merge or any later app implementation PR
Programme effect	P01-01 merge, Gate A0 and dependent implementation PRs remain blocked until the live control is active and verified.
Independent recommendation	Approved: GitHub Team for three billable users at approximately $12 USD/month before tax. Expenditure is authorized but not yet incurred. Alan owns activation-time ruleset design and evidence; Gate A0 and dependent implementation PRs remain blocked until Team is active, both checks are mandatory, routine bypass is restricted, and negative-bypass evidence is accepted.

Implementation risk	Owner	Treatment
CI exposes existing backend drift	Alan	Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate.
Tests accidentally depend on protected branch code	Alan	Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate.
Secrets or DB credentials leak in logs	Alan	Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate.

1.8 Existing-work salvage

Source	Head	Valuable content	Destination	Recommendation	Extraction status/safety
app#122	e85382150853	Case projection/lens surfaces, safe return_to, invitation TTL/CAS/self-member/one-GC constraints, transactional membership, fail-closed Learn, SQL-limited timeline, responsive/a11y tests and Python CI workflow.	P01-01	Selective-port behavior and tests; supersede as programme architecture	Complete at e853821: authoritative behavior/tests and selectively portable implementation are classified; superseded architecture and evidence-only claims are named.
feat/byos-journey-wave-2	5b63e3a7c364	Projection-driven phase-1 cluster presentation, exact route allowlisting, person-versus-case-side ownership intent, transactional submission/work-item and review/audit patterns, fail-closed item retention, approved Learn status selection and 36 focused tests.	P01-01	Preserve paused at the exact head; selectively port semantics/tests only after adaptation. Do not merge, cherry-pick, continue implementation or use its runtime schema directly.	Paused exact-head evidence; no direct merge

Package source inventory:

- PR #122 Python-test workflow and PostgreSQL-compatible test fixes only after reconciliation

1.9 Ownership recommendation

Alan proposes the workflow and test matrix; Luke approves the evidence threshold. Repository-enforced required-check governance remains bounded by D-CI-01, but the workflow itself can land after programme acceptance.

PR	WP DRI	Primary implementer	Technical-decision owner	Reviewer	Final approver	Exception
P01-01	Alan	Alan (proposed)	D-CI-01: Alan - immediate control configuration/evidence	Luke	Luke	None

PR ownership inherits the proposed work-package split pending Alan's review. Named technical-decision ownership remains separate and never transfers implementation ownership across work packages; reciprocal and external review requirements remain intact.

1.10 Definition of done

- ☐ Every proposed PR is merged in dependency order or explicitly dispositioned, with its objective acceptance criteria and review record complete.
- ☐ All package blocking decisions are resolved by the named owner; no commercial/privacy/security value is guessed in code.
- ☐ Local, PostgreSQL, role/authorization, retry/concurrency, failure, mobile and synthetic-cloud evidence required by this package is attached.
- ☐ Cross-repository contracts and artifact/migration versions are pinned; partial-merge behavior is fail-closed or explicitly degraded.
- ☐ Observability is sufficient to identify revision, transition, dependency and safe failure without sensitive payloads.
- ☐ Existing PR/worktree value and reviewer findings are extracted before closure; no cleanup occurs without team confirmation.
- ☐ The associated programme gate is accepted by Luke and any required external reviewer; tests/deploy alone do not establish B1/B2.